



Scry 软件产品说明书

Scry 安全智能运维平台

文档版本：1.0.0

产品名称：Scry 安全智能运维平台

适用平台：麒麟高级服务器操作系统 V11、LoongArch64

适用人员：比赛评审、系统管理员、运维工程师、安全审计人员

编制日期：2026-07-20

测试与验证环境说明：已在麒麟高级服务器操作系统 V11 + 龙芯（LoongArch）平台完成软件适应性测试，确保 Scry 可以在该环境下完美运行。考虑到麒麟-龙芯实体环境的持续使用成本，除适应性测试外，现阶段其他功能与性能测试主要在 macOS 开发环境及其中运行的麒麟系统虚拟机中开展；后续将在麒麟-龙芯平台补充相应测试。

1. 产品概述

Scry 是面向麒麟操作系统和企业 Linux 节点的安全智能运维平台。产品采用 B/S 架构，在同一 Web Console 中整合指标、日志、链路、基础设施、消息队列、告警、智能运维 Agent、MCP 工具、证据链、运行记忆、Loop 自动化和最小权限执行。

Scry 的核心价值不是让模型获得任意 Shell，而是将自然语言请求转化为可审查的计划和有 Schema 的工具调用，并由服务端安全组件决定是否允许、要求审批或拒绝。所有感知、判断、操作和验证均可按 traceId 回放。

2. 产品组成

模块	用户可见能力
可观测工作台	服务、Trace、日志、指标、基础设施、消息队列、仪表盘和告警
Agent Workspace	诊断、规划、操作三种模式，Thread、计划、工具状态和结构化结果
证据系统	证据评分、关系、采纳、驳回、挂起、备注和证据约束重答
Memory Manager	运行记忆、分块、来源、服务拓扑、检索和维护
Workflow Manager	Loop 编排、条件、并行、循环、审批、操作、验证、Cron 和事件触发
工具与安全	模型、MCP 插件、SSH 主机、工具策略和安全审计
故障模拟	多信号故障数据、隐藏真值和 Agent 准确性评测

3. 运行环境

3.1 目标生产环境

- 麒麟高级服务器操作系统 V11。
- LoongArch64/loong64 处理器架构。
- Node.js 22、Go/CGO 工具链、Nginx、systemd。
- PostgreSQL、ClickHouse、OpenTelemetry Collector、Alertmanager。

- 现代 Chromium 内核浏览器。

3.2 开发和演示环境

软件已在麒麟 V11 + 龙芯（LoongArch）平台完成适应性测试，能够完美运行。受实体测试环境持续使用成本影响，其他日常功能与性能测试主要使用 macOS 研发工作站，并在 macOS 中运行麒麟系统虚拟机进行开发期验证。完整服务可通过 Docker Compose 启动，默认地址：

服务	地址
Web Console	http://localhost:3301
Query Service	http://localhost:8080
Agent Service	http://localhost:4111
MCP	http://localhost:4111/mcp

4. 安装与启动

4.1 开发环境启动

```
cp .env.example .env
```

编辑 `.env`，至少设置长度不小于 32 字符的 `SCRY_AGENT_MASTER_KEY`，并替换默认数据库密码。随后执行：

```
make -f Makefile.dev dev
```

启动后检查：

```
curl http://127.0.0.1:4111/health
curl 'http://127.0.0.1:8080/api/v1/health?live=1'
curl http://127.0.0.1:3301/
```

4.2 麒麟 V11/LoongArch64 安装

在目标机解压发布包后执行：

```
cd deploy/kylin-loong64
sudo ./build-node.sh
sudo SCRY_POSTGRES_PASSWORD='替换为强密码' ./setup-postgres.sh
./preflight.sh
./build-query.sh
./build-agent.sh
./build-frontend.sh
sudo ./install-native.sh
sudo ./acceptance.sh
```

`preflight.sh` 未通过时不要继续安装。`acceptance.sh` 将检查处理器架构、PostgreSQL、Scry 服务、Nginx、健康接口、目录属主和非 root 运行用户。

4.3 安装受管主机代理

在每台需要被 Agent 巡检或受控操作的 Linux 主机上准备 `scry-ops` 公钥，然后执行：

```
cd deploy/scry-ops
sudo ./install.sh /path/to/scry-ops.pub
```

编辑 `/etc/scry-ops/allowed-services`，每行填写一个允许执行受控服务操作的 systemd unit。完成后确认：

- `scry-ops` 不能登录交互 Shell。
- 包装器和配置为 `root:root`，运行账户不可写。
- sshd 禁止 TTY、端口转发和隧道。
- sudoers 只包含精确包装器路径。

5. 首次配置

5.1 登录与角色

使用平台账号登录。管理员可配置系统；编辑者可进行日常观测、诊断和运行已授权 Loop；只读用户只能查看授权资源。若界面入口不可见或接口返回 403，应由管理员检查用户角色，而不是修改前端代码绕过。

5.2 配置模型

进入“设置 -> 工具与安全 -> 模型设置”：

1. 选择 OpenAI Responses、Anthropic Messages 或兼容端点。
2. 填写模型名称、Base URL 和 API Key。

3. 设置温度、最大输出、最大步骤、超时、重试和工具选择。
4. 点击连接测试。
5. 保存配置。

API Key 加密保存，列表与页面只显示是否已配置。若测试失败，检查模型端点网络、模型 ID、证书、代理和配额。

5.3 配置远程 MCP 插件

进入“MCP 插件”：

1. 新建插件，填写名称和 HTTP(S) URL。
2. 按需要填写独立认证头和 1,000 至 120,000 ms 超时。
3. 保存后点击“测试连接”。
4. 确认工具列表和 Schema 正常后启用。

插件 URL 不得包含用户名或密码。系统不会向远程插件转发用户的 Scry JWT；认证头由管理员单独配置并加密保存。

5.4 配置 SSH 主机

进入“SSH 主机”：

1. 填写名称、主机地址、端口和固定用户名 `scry-ops`。
2. 探测并人工核对主机密钥指纹。
3. 配置公钥认证材料。
4. 保存并执行连接测试。
5. 先运行“最小权限环境校验”，确认 UID、组、ForceCommand、包装器属主和权限。

禁止配置 root 用户或使用密码方式绕过 `scry-ops`。主机指纹发生变化时必须重新核实，不能直接接受。

6. 日常使用

6.1 查看系统状态

通过左侧导航进入服务、Trace、日志、指标、基础设施、消息队列、仪表盘或告警页面。建议先确定统一时间范围，再从异常服务跳转到端点、Trace 和日志，保持证据时间一致。

6.2 使用 Agent 诊断故障

进入 Agent Workspace，创建 Thread，选择“诊断”模式并输入明确症状。例如：

过去 15 分钟订单服务的 P95 延迟明显上升，请结合链路、日志、主机指标和当前告警定位根因。区分根因、传播结果和无关干扰项，并给出验证步骤。

推荐问题包含：时间范围、目标服务或主机、用户症状、允许使用的信号和期望输出。Agent 会发布计划、调用工具、显示证据，并输出结论、证据、下一步和不确定性。

不要在问题中要求直接执行无边界命令。需要操作时先在“规划”模式审查步骤，再切换“操作”模式。

6.3 规划与执行受控操作

以服务恢复为例：

1. 在诊断模式确认服务异常及证据。
2. 切换规划模式，要求输出风险、回滚和验证条件。
3. 切换操作模式，选择管理员预配置的操作 ID。
4. 阅读审批信息，确认目标主机、服务、参数和风险。
5. 审批后系统通过 `scry-ops` 执行。
6. 系统重新读取服务状态、端口、告警和关键指标。

若目标或参数发生变化，原审批自动失效。系统拒绝 root、任意 Shell、管道、重定向、命令替换和未登记服务。

6.4 管理证据

在 Agent 检查器中查看每项证据的来源、摘要、评分、状态和关系：

- “采纳”表示确认该证据可用于结论。
- “驳回”表示证据错误或无关，后续回答必须排除。
- “挂起”表示存在安全或真实性疑问。
- “备注”用于记录人工判断。
- “选择”决定证据约束重答使用的范围。

选择证据后可补充要求并触发重新回答。该过程不调用新工具，关键判断引用证据 ID，便于评审检查事实依据。

6.5 使用运行记忆

Memory Manager 保存服务画像、Runbook、故障模式、处置和验证记录。用户可按服务、类型、状态和关键词检索，查看分块、来源和关系。

TopoMem 会在当前 Trace 存在时沿异常调用路径定位候选根服务，再使用错误签名选择故障模式。记忆内容仍需结合当前实时证据，不得因历史记录存在就跳过现场取证。

项目随附 `main.pdf` 的受控评测覆盖 55 个独立故障和 548 份运维文档：TopoMem-Walk 的 Root Hit@5 为 0.927，完整 TopoMem 为 0.964；固定 Agent 配置的 24 个故障实验中，错误首个工具目标率降至 0.08，两次工具调用内到达根服务的比例为 1.00。完整数据见《软件性能（核心指标）测试报告》的“TopoMem 全量评测数据”章节。

6.6 创建和运行 Loop

进入 Workflow Manager：

1. 新建 Loop，填写名称、说明、标签和输入字段。
2. 添加查询、分析、安全检查、条件、并行、循环、审批、操作和验证节点。
3. 配置手动、Cron 或事件触发器。
4. 保存并检查结构校验结果。
5. 输入参数并运行，在历史中查看步骤、分支和结果。

变更型流程应显式包含审批与验证。即使自定义流程遗漏安全节点，底层输入和工具安全检查仍然执行。

7. 典型操作示例

7.1 磁盘爆满诊断与清理

推荐使用预设“磁盘爆满诊断与清理”：

1. 读取磁盘使用率和告警。
2. 检查大文件和近期系统错误。
3. 区分可清理文件与数据库/审计关键文件。
4. 形成清理计划和风险说明。
5. 人工审批。
6. 执行固定清理包装器。
7. 验证空间、服务和告警恢复。

若证据不足，系统应停止在建议阶段，不执行删除。

7.2 僵尸进程诊断

使用预设“僵尸进程诊断”，读取进程关系和系统日志，优先定位父进程未回收问题。结果应包含父进程、数量趋势、影响、修复建议和验证方法，不得用批量强杀替代根因修复。

7.3 综合根因分析

预设“综合根因分析”并行读取服务、告警和仪表盘，结合 Trace、日志、指标和记忆形成因果链。输出应明确：

- 根因服务与故障机制。
- 支撑结论的字段或数值。
- 上游传播结果。
- 按风险排序的处置。
- 恢复验证和禁止执行的动作。

8. 故障模拟与准确性评测

管理员可在“故障模拟”中选择场景、强度、生成间隔和信号类型。模拟数据带 `scry.debug=true` 与不透明 case ID，不携带根因标签。

端到端准确性评测命令：

```
SCRY_TEST_TOKEN='<管理员 JWT>' \  
node tests/accuracy/debug-scenario-accuracy.mjs \  
  --cases case-001,case-005,case-007 \  
  --batches 3 \  
  --output output/accuracy/report.json
```

也可使用 `--all` 评测全部场景。评测会生成数据、等待入库、创建隔离 Thread、调用 Agent、读取证据并按根服务、根因、证据、处置、验证和安全评分。生产环境使用前应确认调试功能只对管理员开放。

9. 安全审计

进入“安全审计”，可按 traceId、用户、事件和时间检查：

- 指令接收和输入哈希。
- Prompt Injection 扫描结果。
- 意图分类和策略裁决。
- 审批要求与参数绑定。
- 命令风险复检。
- 工具开始、完成或失败。
- 执行结果和验证。

审计不保存模型 Key、MCP 认证头、SSH 私钥或完整敏感输出。若需要调查某次操作，应以 traceId 为主线，结合 SSH 专项审计中的退出码、耗时和输出字节数。

10. 常见问题

现象	检查方法
Agent 健康接口失败	检查 <code>scry-agent</code> 状态、主密钥、PostgreSQL、数据目录权限和日志
登录后接口 401	检查 JWT、Query Service 和角色查询接口
管理页面 403	当前角色不是 ADMIN，联系管理员调整授权
MCP 插件无工具	检查 URL、认证头、超时、TLS 和 initialize/tools/list 响应
SSH 连接被拒绝	检查 <code>scry-ops</code> 用户、公钥、ForceCommand、指纹和包装器权限
操作始终要求审批	变更和操作模式按设计必须审批，不应关闭该控制
危险命令被拒绝	改用管理员登记的工具或 <code>scry-ops</code> 包装器，不要尝试绕过
Loop 长时间排队	检查实例/组织/Loop 并发、Dispatcher、Worker 租约和下次重试时间
诊断证据不足	缩小时间范围、明确服务/主机、检查 OTLP 接入和 Query Service
外部内容被挂起	内容命中注入规则，需人工核验后才能恢复使用

11. 数据备份与升级

- 备份 PostgreSQL Agent 运行库。
- 备份 WASM SQLite 配置、对话、证据、记忆、策略和审计数据库。
- 备份 ClickHouse 遥测按组织制定保留策略。
- 保存 `.env`、Nginx、systemd、`allowed-services` 和主机指纹配置，但秘密备份必须加密。
- 升级前校验发布包 SHA-256，先在测试环境执行数据库迁移、构建和验收。
- 升级后运行健康、权限、MCP、安全、SSH 和关键 Loop 回归测试。

12. 产品边界与注意事项

1. Agent 结论依赖实时遥测质量；没有证据时应输出不确定性。
2. 外部模型延迟和可用性由模型提供方影响，但本地安全裁决不依赖模型。
3. 软件已通过麒麟-龙芯平台适应性测试；受实体环境成本影响，其他测试主要在 macOS 开发环境和麒麟系统虚拟机中开展，后续将在麒麟-龙芯平台补充测试。
4. `scry-ops` 是最小权限边界，禁止为方便演示改成 root 或开放任意命令。
5. 调试数据只能用于演示和评测，清理时必须按 debug 标识限定范围。

13. 建议比赛演示流程

在 7 分钟演示中建议按以下顺序：

1. 展示麒麟 V11/LoongArch64、服务状态和 Web Console。
2. 启用一个磁盘、僵尸进程或复合故障场景。
3. 用自然语言要求 Agent 诊断，展示计划和并行工具取证。
4. 展示证据评分、Trace 关联、TopoMem 记忆和根因结论。
5. 提交提示词注入或危险命令，展示拒绝和 traceId。
6. 运行带审批的恢复 Loop，展示 `scry-ops` 最小权限执行与复验。
7. 在安全审计中回放“输入 - 感知 - 决策 - 审批 - 执行 - 验证”。

该流程覆盖赛题的 OS 感知、MCP、自然语言准确性、安全护栏、最小权限、推理链路、根因分析和创新实用性。